ISMS審査 提出資料一覧（個人情報漏えい 机上訓練）

提出資料の一覧・実施概要・主な結果・今後の対応

ISMS審査 提出用 | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

提出日: 2026-10-02
対象: 2026-10-02（金）15:00 - 16:00 に実施した個人情報漏えいインシデントの机上訓練
提出者: 空（訓練の企画・進行・記録）

> **本訓練で扱った不具合は架空のものです。** 実際に発生した事象ではありません。
> 実在の顧客データの漏えいは発生していません。

1. 提出資料

#	資料	内容	位置づけ
1	訓練の概要と準備	実施設定・体制・事前準備の手順	計画
2	ファシリテーター用進行台本	進行手順・投入する情報・観測項目・振り返りの進め方	計画（詳細）
3	Slack投入用テキスト	当日投入した文面の一式	計画（詳細）
4	**訓練実施記録**	時系列51件・測定結果・投票結果	**実施記録**
5	**訓練実施報告**	結果の評価、よくできていたこと、見つかった空白8点	**レビュー**
6	参加者配布資料	訓練後に全参加者へ配布した解説資料（法令の要点を含む）	教育

資料2・3には訓練シナリオの内容が含まれるため、**社内では進行役のみが保持**しています。
審査に際しては、計画の妥当性を確認いただくために提出します。

2. 実施の概要

項目	内容
目的	インシデント対応フローを整備するにあたり、**現状で決められないことを洗い出す**
形式	机上訓練。実システムには一切触れない
実施方法	**Slack完結型。**会議体を設けず、参加者は通常業務と並行して対応
参加者	ISMS管理者・CS・エンジニアを含む11名（投票参加者数）
シナリオ	管理画面のCSVダウンロード機能の不具合により、顧客が取得したCSVに他社データが混入
事前共有	**進行役1名を除き、シナリオは誰にも共有していない**（ISMS管理者を含む）

会議を設けなかった理由: 実際のインシデントは通常業務中にSlackで始まります。
通知に気づくか、片手間で初動が回るかは、会議を設定した訓練では測れないためです。

---

3. 主な結果

項目	結果
第一報 → 最初の反応	約2分
第一報 → ISMS管理者へ到達	約10分
原因特定から修正リリースまで（止血）	**48分**
実システムへの接触	なし（ルールどおり）
顧客との共有チャンネルへの社内議論の流出	1回（注意後は発生せず）

初動と止血は速く、影響範囲についても「指摘してきた1社」に閉じず、
閲覧された側の顧客まで対象になるという点に、誘導なしで到達しています。

一方で、以下が決まっていないことが確認されました（詳細は資料5）。

#	見つかった空白
1	インシデント専用チャンネルの運用（今回は作られず、既存3チャンネル5スレッドに分散）
2	**証跡保全の手順**（指示が誰からも出なかった）
3	委託／自社取得の契約上の整理（報告主体の判断に直結。混入元への通知方針が未決）
4	機能の一時停止の判断権限
5	扱うデータ項目の個人情報該当性の整理
6	顧客への連絡文面のテンプレート
7	音声へ切り替える基準と、決定の書き戻しルール
8	**調査体制**（依頼は2名宛だったが、実際に動いたのは1名。役割を分けるルールがない）

---

4. 今後の対応

見つかった空白は、担当と期限を付けたアクションとして管理を開始しています（12件）。

現時点では担当・期限の割り当てが完了していないため、本提出資料には含めていません。
進捗および今後の計画については、**審査時に口頭でご報告します。**

予定している対応	概要
対応フローの整備	上記の空白1〜8を章立てとしたドラフトを作成し、関係者レビューを経て確定
技術面の点検	集計処理のリリース前チェック、操作ログの保全状況の確認
確認方法	**訓練の再実施は行わず**、ドラフトの関係者レビューで確認

技術面の点検は、**今回の不具合が架空である**ことから「再発防止」ではなく
「同じことが起こり得る箇所の未然点検」として扱います。

---

5. 参考：関連する管理策

本訓練および今後の対応が関係すると考えている管理策です。
最終的な対応付けは ISMS管理者の判断によります。

管理策	本訓練との関係
A.5.24 情報セキュリティインシデント管理の計画及び準備	対応フローが未整備であることの確認と、整備の着手
A.5.25 情報セキュリティ事象の評価及び決定	「疑い」の段階で上げる判断、報告対象かどうかの判断
A.5.26 情報セキュリティインシデントへの対応	初動・調査・止血・顧客連絡の一連の実施
A.5.27 情報セキュリティインシデントからの学習	訓練結果の分析と、アクションへの変換
A.5.34 プライバシー及びPIIの保護	個人情報保護法上の報告義務・該当者への通知の検討
A.6.3 情報セキュリティの意識向上、教育及び訓練	全参加者への配布資料による教育、無罰ルールの周知
